



Guaranty Trust Bank Ltd

Linux Kernel 'Dirty Frag' Local Privilege Escalation

CONFIDENTIAL



Guaranty Trust Bank Ltd

Table of Contents

1. Executive Summary
2. Threat Analysis
3. Indicators of Compromise (IOCs)
4. Detection Methods
5. Assessment
6. Remediation & Action Plan
7. References

CONFIDENTIAL



Guaranty Trust Bank Ltd

Report Title: CVE-2026-43284 / CVE-2026-43500: Linux Kernel 'Dirty Frag' Local Privilege Escalation

Date: May 8, 2026

Prepared By: David Odigie

Reviewed By: Fatima Jinadu

Organization/Unit: Security Monitoring and Threat Intelligence

1. Executive Summary

A critical local privilege escalation (LPE) vulnerability chain, dubbed **Dirty Frag**, has been publicly disclosed on May 7, 2026 by security researcher **Hyunwoo Kim (@v4bel)**. Dirty Frag chains two distinct page-cache write vulnerabilities **CVE-2026-43284** (xfrm-ESP) and **CVE-2026-43500** (RxRPC) to achieve deterministic root privilege escalation on virtually all major Linux distributions.

Dirty Frag extends the same bug class as **Dirty Pipe (CVE-2022-0847)** and **Copy Fail (CVE-2026-31431)**. It is a **straight-line logic flaw** that does not depend on timing windows or race conditions. The kernel does not panic on failed exploitation, and success rates are very high. A working proof-of-concept exploit is publicly available and can achieve root in a single command.

Critically, Dirty Frag can be triggered **regardless of whether the algif_aead module is available**. Even systems where the Copy Fail mitigation (algif_aead blacklist) has been applied remain fully vulnerable to Dirty Frag. The vulnerability affects all Linux kernels from approximately **4.14 (January 2017)** onward, with the RxRPC component introduced in **June 2023**.

Critical Impact: Dirty Frag bypasses the Copy Fail mitigation entirely. Organisations that applied the algif_aead blacklist in response to CVE-2026-31431 are still exposed. The exploit chains two complementary primitives xfrm-ESP (requires user namespace creation, blocked by Ubuntu AppArmor) and RxRPC (does not require namespaces, but module not shipped on RHEL by default) making the combined attack universal across distributions.

2. Threat Analysis

Guaranty Trust Bank Ltd

Dirty Frag exploits the in-place decryption fast paths of the Linux kernel's networking subsystems. When a socket buffer carries paged fragments that are not privately owned by the kernel (e.g., pipe pages attached via splice(2), sendfile(2), or MSG_SPLICE_PAGES), the receive path decrypts directly over those externally-backed pages. This exposes or corrupts plaintext that an unprivileged process still holds a reference to, enabling controlled writes into the page cache of sensitive files such as /usr/bin/su or /etc/passwd.

Attack Chain

1. Foothold Established	Attacker obtains low-privileged local shell access via compromised service account, web shell, CI pipeline, or container workload. No elevated privileges or network access required.
2. User Namespace Creation (ESP path)	Attacker creates a user namespace and network namespace to gain CAP_NET_ADMIN capabilities within the namespace. This step is blocked by Ubuntu's AppArmor default policy, forcing fallback to the RxRPC path.
3. AF_XFRM Socket Setup	Attacker opens an AF_NETLINK socket and configures an xfrm Security Association (SA) for ESP-in-UDP encapsulation on localhost. This is a standard IPsec configuration operation requiring no host-level privileges.
4. splice() Page Cache Poisoning	Attacker splices a target file (e.g., /usr/bin/su) into the ESP socket. Due to the in-place decryption flaw, the kernel writes decrypted data directly into the file's page cache pages, corrupting the in-memory binary.
5. Controlled Page-Cache Write	The attacker controls the overwrite via splice offset, splice length, and ESP sequence number parameters. This allows precise targeting of the .text section of setuid binaries to inject shellcode.
6. Privilege Escalation to Root	When the corrupted /usr/bin/su is executed, the injected shellcode runs with setuid privileges, granting UID 0. The entire operation is in-memory; no disk modifications occur.
7. RxRPC Fallback (if namespaces blocked)	On systems where user namespace creation is restricted (e.g., Ubuntu with AppArmor), the attacker leverages the RxRPC subsystem instead. The rxrpc.ko module is loaded by default on Ubuntu, providing an alternative page-cache write primitive without namespace requirements.

Technical Abuse & Evasion

- Deterministic exploitation no race conditions, no timing windows, no kernel panics on failure. Success rate is very high.
- In-memory corruption only page cache is modified, not disk files. File integrity monitoring (FIM) tools will not detect exploitation.
- Bypasses Copy Fail mitigation works even when algif_aead is blacklisted or the system is patched for CVE-2026-31431.
- Cross-distribution coverage chaining ESP and RxRPC primitives covers environments where either user namespaces or the rxrpc module is available.



- Container escape capable the page cache is shared across host and containers. Corrupting host setuid binaries from within a container is possible.
- Public exploit available a working PoC was released alongside disclosure, achieving root in a single command.

Guaranty Trust Bank Ltd

Affected Distributions

- Ubuntu 20.04, 22.04, 24.04.4 (rxrpc.ko loaded by default; AppArmor blocks namespaces RxRPC path viable)
- RHEL 8, 9, 10 / CentOS Stream 10 / AlmaLinux 8, 9, 10 / Rocky Linux (esp4/esp6 built-in; rxrpc not shipped by default ESP path viable)
- Fedora 44 (both paths viable)
- openSUSE Tumbleweed (both paths viable)
- Amazon Linux 2023 (ESP path viable)
- OpenShift 4 (potentially affected under investigation)

MITRE ATT&CK Mapping

Technique ID	Technique Name	Context
T1068	Exploitation for Privilege Escalation	Local kernel LPE via CVE-2026-43284 / CVE-2026-43500
T1611	Escape to Host	Container escape via shared page cache poisoning
T1548.001	Abuse Elevation Control Mechanism: Setuid and Setgid	Corruption of setuid binary page cache
T1059.004	Command and Scripting Interpreter: Unix Shell	Initial foothold for local execution
T1078.003	Valid Accounts: Local Accounts	Any local unprivileged user can trigger the flaw
T1497.001	Virtualization/Sandbox Evasion	User namespace creation to gain capabilities
T1552.001	Credentials In Files	Targeted corruption of /etc/passwd or credential stores



Guaranty Trust Bank Ltd

3. Indicators of Compromise (IOCs)

Type	Indicator	Description
CVE ID	CVE-2026-43284	xfrm-ESP Page-Cache Write vulnerability (IPsec subsystem)
CVE ID	CVE-2026-43500	RxRPC Page-Cache Write vulnerability (AFS/RxRPC subsystem)
CVSS Score	7.8 (HIGH)	CVSS 3.1 Local, Low Complexity, No Privileges Required
Kernel Modules	esp4, esp6, rxrpc	Vulnerable in-place decryption fast paths
Kernel Versions	4.14 present	ESP flaw introduced January 2017; RxRPC flaw introduced June 2023
File Path	/etc/modprobe.d/dirtyfrag.conf	Mitigation config file path for blacklisting vulnerable modules
PoC	dirtyfrag.io / oss-security	Public proof-of-concept exploit achieves root in single command
Exploit Alias	Copy Fail 2: Electric Boogaloo	Alternative public exploit targeting same vulnerability chain

4. Detection Methods

Manual Checks

Check if vulnerable modules are loaded:

```
lsmod | grep -E 'esp4|esp6|rxrpc'
```

Check running kernel version:

```
uname -r
```

All kernels 4.14 and above are vulnerable until patched.

Verify module blacklist (mitigation check):

```
cat /etc/modprobe.d/dirtyfrag.conf
```

Expected output if mitigation applied:

```
install esp4 /bin/false
```

```
install esp6 /bin/false
```

```
install rxrpc /bin/false
```

Check for user namespace creation (Ubuntu/AppArmor):

```
sysctl kernel.unprivileged_userns_clone
```

Value 0 blocks the ESP path; 1 allows it.

Check if rxrpc module is available:

```
modinfo rxrpc 2>/dev/null && echo 'rxrpc available' || echo 'rxrpc not available'
```



Guaranty Trust Bank Ltd

5. Assessment

Following our environment assessment, we have identified 50 endpoints running vulnerable kernel versions susceptible to CVE-2026-43284 / CVE-2026-43500 (Dirty Frag). Affected kernels include 4.14.35, 4.18.0, 5.14.0, 5.15.0, and 6.12.0 all falling within the vulnerable range and lacking the upstream fixes present in 6.12.30, 6.14.5, and 6.15-rc4. The esp4, esp6, and rxrpc kernel modules are active or available on these systems, exposing the in-place decryption attack surface to unprivileged local users. Notably, Dirty Frag bypasses existing Copy Fail mitigations entirely endpoints where algif_aead was previously blacklisted remain fully exposed. Given the deterministic exploitation, container escape risk via shared page cache, and absence of disk-based forensic artifacts, these 50 endpoints represent a critical and immediate security exposure requiring urgent mitigation.

6. Remediation & Action Plan

Immediate Mitigation (No Reboot Required)

Disable the vulnerable kernel modules on all affected systems immediately:

```
sudo sh -c "printf 'install esp4 /bin/false\ninstall esp6 /bin/false\ninstall rxrpc /bin/false\n' > /etc/modprobe.d/dirtyfrag.conf; rmmod esp4 esp6 rxrpc 2>/dev/null; true"
```

Note: This mitigation does not affect IPsec VPN tunnels using IKEv2 (strongSwan, libreswan) or WireGuard. It specifically blocks ESP transport mode via the kernel's xfrm subsystem. If your environment uses IPsec transport mode, test before applying universally. RxRPC is used by AFS (Andrew File System) disable only if AFS is not in use.

If compromise is suspected before mitigation, drop the page cache to evict any tampered pages:

```
sudo sh -c 'echo 3 > /proc/sys/vm/drop_caches'
```

This is safe on a live system it only frees clean cache and dentry/inode entries.

Apply Patched Kernel (Priority Action)

Apply the vendor-supplied patched kernel as soon as available. Prioritise: **Kubernetes nodes, CI/CD runners, multi-tenant systems, and systems with untrusted user access.**

- AlmaLinux: Patched kernels available in testing repository (kernel-4.18.0-553.123.2.el8_10, kernel-5.14.0-611.54.3.el9_7, kernel-6.12.0-124.55.3.el10_1)
- RHEL: Fixes expedited monitor RHSB-2026-003 for updates



- Ubuntu: Pending vendor release apply module blacklist in interim
- Other distros: Monitor vendor security advisories

Guaranty Trust Bank Ltd

Boot-Time Mitigation (Alternative if rmmod fails)

Add module blacklist to kernel command line via grubby:

```
grubby --update-kernel=ALL --args="module_blacklist=esp4,esp6,rxrpc"
```

This prevents the modules from loading at boot and requires a reboot.

Kubernetes & Container Environments

Treat Kubernetes nodes as the highest priority. An exploited container can escape to the host node via shared page cache. **Patch or mitigate all nodes before re-enabling untrusted workload execution.**

Copy Fail Mitigation Review

If your organisation applied the algif_aead blacklist in response to CVE-2026-31431, understand that **Dirty Frag bypasses this mitigation entirely**. The esp4/esp6/rxrpc blacklist must be applied in addition to not instead of any existing Copy Fail mitigations. Do not remove the algif_aead blacklist; simply add the Dirty Frag modules to your blacklist.

7. References

#	Source	URL
1	Hyunwoo Kim Dirty Frag Researcher Advisory	https://dirtyfrag.io
2	oss-security Mailing List Dirty Frag Public Disclosure	https://www.openwall.com/lists/oss-security/2026/05/07/8
3	The Hacker News Linux Kernel Dirty Frag LPE Exploit	https://thehackernews.com/2026/05/linux-kernel-dirty-frag-lpe-exploit.html
4	AlmaLinux Dirty Frag Vulnerability Fix	https://almalinux.org/blog/2026-05-07-dirty-frag/
5	Red Hat RHSB-2026-003 Networking Subsystem Privilege Escalation	https://access.redhat.com/security/vulnerabilities/RHSB-2026-003
6	Wiz Dirty Frag Linux Privilege Escalation	https://www.wiz.io/blog/dirty-frag-linux-kernel-local-privilege-escalation-via-esp-and-rxrpc
7	cPanel Support Dirty Frag Vulnerability Report	https://support.cpanel.net/hc/en-us/articles/40313772552727-Dirty-Frag-vulnerability-reported-for-Linux-kernel
8	NHS Digital Proof-of-Concept Exploit Released	https://digital.nhs.uk/cyber-alerts/2026/cc-4779
9	NVD CVE-2026-43284	https://nvd.nist.gov/vuln/detail/CVE-2026-43284
10	MITRE ATT&CK T1068: Exploitation for Privilege Escalation	https://attack.mitre.org/techniques/T1068/